STRIDE ISP 4.4 – PR.PS

Platform Security Standards

Version [2.0]

Purpose:

This document defines the Stride standards related to Information Protection Processes and Procedures.

Scope and Applicability

These policies and standards apply to all Stride-owned technology and business operations.

All workforce members and their respective facilities supporting Stride business operations, technology, or both, wherever Stride data is stored or processed, including any third party contracted by Stride to handle, process, transmit, store, or dispose of Stride data are subject to the requirements of this document.

All data, systems, activities, and assets owned, leased, controlled, or used by Stride, its agents, contractors, or other business partners on behalf of Stride are within the scope of the requirements of this document.

The requirements outlined in this document apply where technically feasible and commercially reasonable, as determined by executive management. Any exceptions to these standards must be requested using the approved workflow and remain documented until compliance has been achieved. Exceptions are only granted temporarily for periods of up to one calendar year.

Definitions

All definitions are located within Stride - ISP 1.2 – IT Policy Definitions.

Any inquiries regarding terminology or clarity may be directed to Stride's Information Security Team for assistance.

Publication Owners

Johnny Burns – Point of Contact, Content Coordinator & Author

Jen Havenner – Business Owner

Mark Williams – Executive Sponsor

Document Control

This document may contain proprietary, confidential, or sensitive information owned wholly by Stride Inc. Any distribution of the information contained within this document, in whole or in part, outside of Stride or its subsidiary entities requires the approval of the Executive Sponsor.

This document will be reviewed at least annually and re-issued when revisions are necessary. Any changes introduced in the most recent version are itemized below. Obsolete copies should be destroyed or archived upon the release of the newest version.

Implementation and Compliance

All business units are required to comply with any changes applied to the most recent version of this publication within 90 days from the date of publication.

Change History

Version	Date of Change	Summary of Change(s)
1.0	06/15/2022	- Initial Release and Publication
1.1	12/01/2022	- Added Change History - Updated and/or redacted language for clarity where necessary
1.2	03/17/2023	- Updated approvals section
1.3	01/01/2024	- Updated Purpose/Scope/Document Control/Implementation and Compliance - Changed formatting to new standard - Changed document images
2.0	02/17/2025	- Major change to align with NIST 2.0
2.0	02/24/2025	- Approved Mark Williams - CISO
2.0	02/27/2025	- Published

INFORMATION PROTECTION PROCESSES & PROCEDURES STANDARDS

Policy on Information Protection Processes & Procedures:

Security policies (that address purpose, scope, roles, responsibilities, management commitment, and coordination among organizational entities), processes, and procedures are maintained and used to protect information systems and assets.

PR.PS-01 CONFIGURATION MANAGEMENT PRACTICES

The hardware, software (e.g., firmware, operating systems, applications), and services of physical and virtual platforms are managed consistent with the organization's risk strategy to protect their confidentiality, integrity, and availability.

Standards:

- The organization must establish and apply comprehensive configuration management practices to ensure the secure and efficient operation of its IT infrastructure. These practices should include the following elements:

  Configuration Management Policy

  - Develop, document, and implement a Configuration Management Policy: The policy should define the processes and procedures for managing the configuration of all IT assets, including hardware, software, and services.

  - Regular Review and Update: Ensure the policy is reviewed and updated regularly to reflect changes in the organization’s IT environment and emerging threats.

  Configuration Baselines

  - Define Security Configuration Settings: Establish and document security configuration settings for all IT assets.

  - Establish Restrictions: Define restrictions pertaining to the use of nonessential programs, functions, ports, protocols, and services.

  - Apply the Principle of Least Functionality: Ensure systems are configured to provide only essential capabilities.

  - Review and Update Baselines: Review baselines at a minimum annually, or when system components are installed or upgraded.

  - Central Repository: Store baseline configurations in a central repository for authorized personnel to access, documenting changes and updating repositories accordingly.

- Version Control: Retain previous versions of baselines to support rollback.

Change Control and Change Management

- Ensure all changes to the IT production environment are subject to Change Management
- Document all change requests.
- Adhere to all requirements outlined in the Change Management process.
- Obtain approval from the solicited change request approvers that are systematically generated by the IT Operations ticketing system for that change request type before implementing the change into the production environment.
- Test all non-emergency changes in a non-production environment when possible and track them in the IT Operations ticketing system.
- Maintain records of changes in the ticketing system.

Configuration Monitoring and Auditing

- Continuous Monitoring: Implement continuous monitoring of IT assets to detect unauthorized changes and deviations from approved configurations.
- Periodic Audits: Conduct periodic audits of configuration baselines and changes to ensure compliance with established policies and procedures.
- Incident Response: Establish procedures for responding to detected configuration changes that may indicate a security incident or policy violation.

Documentation and Reporting

- Maintain Documentation: Ensure all configuration management activities are well-documented, including configuration baselines, change requests, approvals, and audit results.
- Reporting: Provide regular reports on configuration management activities to relevant stakeholders, including senior management and compliance officers.

Training and Awareness

- Training Programs: Develop and implement training programs for personnel involved in configuration management to ensure they understand and follow established policies and procedures.

- Awareness Campaigns: Conduct awareness campaigns to promote the importance of configuration management practices across the organization.

References:

- NIST Special Publication 800-218: PO.5.2
- NIST Special Publication 800-218: PS.1.1
- CIS Controls v8.0: 4.1
- CIS Controls v8.0: 4.2
- CRI Profile v2.0: PR.PS-01
- CRI Profile v2.0: PR.PS-01.01
- CRI Profile v2.0: PR.PS-01.02
- CRI Profile v2.0: PR.PS-01.03
- CRI Profile v2.0: PR.PS-01.04
- CRI Profile v2.0: PR.PS-01.05
- CRI Profile v2.0: PR.PS-01.06
- CRI Profile v2.0: PR.PS-01.07
- CRI Profile v2.0: PR.PS-01.08
- CRI Profile v2.0: PR.PS-01.09
- CSF v1.1: PR.IP-1
- CSF v1.1: PR.IP-3
- CSF v1.1: PR.PT-2
- CSF v1.1: PR.PT-3
- Additional guidance may be found within Stride's ServiceNow Knowledge Base: Stride's Change Management Process

PR.PS-02: SOFTWARE MAINTENANCE, REPLACEMENT, AND REMOVAL

Stride has established a standard process for maintaining, replacing, and removing software in a manner that aligns with the organization's risk strategy, ensuring the confidentiality, integrity, and availability of software assets.

Standards:

- Regularly maintain software to ensure it remains up-to-date and secure. This includes applying patches, updates, and fixes to address vulnerabilities and improve functionality.

- Evaluate and replace software that is no longer supported, outdated, or poses a security risk. The replacement process should consider the impact on the organization's operations and the potential risks associated with the transition.

- Securely remove software that is no longer needed or poses a risk to Stride. The removal process should ensure that all data associated with the software is securely deleted and that there are no residual security vulnerabilities.

- Conduct regular risk assessments to identify software that requires maintenance, replacement, or removal. Assessments should consider factors such as software age, vendor support, known vulnerabilities, and the criticality of the software to the Stride's operations.

- Implement configuration management practices to maintain the integrity of software settings and configurations. Ensure that software changes are documented and approved through Stride's change management process.

- Enforce strict access controls to ensure that only authorized personnel can maintain, replace, or remove software. Utilize multi-factor authentication (MFA) and role-based access controls (RBAC) where applicable.

- Test and validate software maintenance, replacement, and removal processes to ensure they are effective and do not introduce new security risks. Conduct regular audits to verify compliance with the established standards.

- Conduct regular training and awareness programs for relevant stakeholders to ensure they understand their roles and responsibilities in maintaining, replacing, and removing software.

- Document the implementation of software maintenance, replacement, and removal protocols and processes to meet organizational and regulatory requirements. Ensure that all changes and updates are properly documented.

References:

- SP 800-218: PO.5.2
- CIS Controls v8.0: 2.2
- CIS Controls v8.0: 2.3
- CRI Profile v2.0: PR.PS-02
- CRI Profile v2.0: PR.PS-02.01
- CRI Profile v2.0: PR.PS-02.02
- CRI Profile v2.0: PR.PS-02.03
- CSF v1.1: PR.IP-12
- CSF v1.1: PR.MA-2

PR.PS-03: HARDWARE MAINTENANCE, REPLACEMENT, AND REMOVAL

Stride has established a standard process for maintaining, replacing, and removing hardware in a manner that aligns with the organization's risk strategy, ensuring the confidentiality, integrity, and availability of software assets.

Standards:

- Regularly maintain hardware to ensure it remains operational and secure. This includes performing routine checks, applying firmware updates, and conducting preventative maintenance to address potential issues before they escalate.
- Evaluate and replace hardware that is no longer supported, outdated, or poses a security risk. The replacement process should consider the impact on Stride's operations and the potential risks associated with the transition.
- Securely remove hardware that is no longer needed or poses a risk to the organization. The removal process should ensure that all data associated with the hardware is securely wiped and that the hardware is disposed of in an environmentally responsible manner.
- Conduct regular risk assessments to identify hardware that requires maintenance, replacement, or removal. Assessments should consider factors such as hardware age, vendor support, known vulnerabilities, and the criticality of the hardware to Stride's operations.

- Implement configuration management practices to maintain the integrity of hardware settings and configurations. Ensure that hardware changes are documented and approved through Stride's change management process.

- Enforce strict access controls to ensure that only authorized personnel can maintain, replace, or remove hardware. Utilize multi-factor authentication (MFA) and role-based access controls (RBAC) where applicable.

- Test and validate hardware maintenance, replacement, and removal processes to ensure they are effective and do not introduce new security risks. Conduct regular audits to verify compliance with the established standards.

- Conduct regular training and awareness programs for relevant stakeholders to ensure they understand their roles and responsibilities in maintaining, replacing, and removing hardware.

- Document the implementation of hardware maintenance, replacement, and removal protocols and processes to meet organizational and regulatory requirements. Ensure that all changes and updates are properly recorded.

References:

- SP 800-218: PO.5.2
- CIS Controls v8.0: 1.2
- CRI Profile v2.0: PR.PS-03
- CRI Profile v2.0: PR.PS-03.01
- CSF v1.1: PR.MA-1
- CSF v1.1: PR.DS-3

PR.PS-04: LOG RECORDS GENERATION AND AVAILABILITY

Stride establishes a standard process for generating and maintaining log records to support continuous monitoring and ensure the confidentiality, integrity, and availability of the organization's technology assets.

Standards:

- The organization must implement comprehensive practices for the generation, retention, and continuous monitoring of log records to ensure the secure and efficient operation of its IT systems. The logs should include but are not limited to:
    - User access and authentication events
    - System and application errors
    - Changes to system configurations and settings
    - Security-related events, such as firewall activity and intrusion detection
- Make log records available for continuous monitoring to authorized personnel and systems. Ensure that logs are stored in a central repository that allows for easy access and analysis.
- Implement measures to protect log records from unauthorized access, alteration, and deletion. This includes encryption, access controls, and regular backups.
- Establish retention policies for log records to ensure they are retained for a period that meets organizational and regulatory requirements. Ensure that older logs are archived securely and can be retrieved when needed.
- Utilize automated monitoring tools and techniques to continuously analyze log records for signs of suspicious activity, security incidents, and system performance issues. Implement alerting mechanisms to notify relevant stakeholders of critical events.
- Conduct regular reviews and analyses of log records to identify trends, anomalies, and potential security threats. Document findings and take appropriate actions to address identified issues.
- Validate log generation, protection, and monitoring processes against documented vendor recommendations and leading industry best practices to ensure robustness and compliance.
    - Adhere to NIST guidelines for log management and continuous monitoring.
    - Implement automated monitoring and alerting tools to detect and respond to critical events.

- Conduct regular training and awareness programs for relevant stakeholders to ensure they understand their roles and responsibilities in generating, protecting, and monitoring log records.

- Document the implementation of log generation, protection, and monitoring protocols and processes to meet organizational and regulatory requirements. Ensure that all changes and updates are properly recorded.

References:

- NIST SP 800-218: PO.3.3
- CIS Controls v8.0: 8.2
- CRI Profile v2.0: PR.PS-04
- CRI Profile v2.0: PR.PS-04.01
- CRI Profile v2.0: PR.PS-04.02
- CRI Profile v2.0: PR.PS-04.03
- CSF v1.1: PR.PT-1

PR.PS-05: PREVENTION OF UNAUTHORIZED SOFTWARE INSTALLATION AND EXECUTION

Installation and execution of unauthorized software are prevented.

Standards:

- Stride maintains a comprehensive practice to prevent the installation and execution of unauthorized software to ensure the secure and efficient operation of its IT systems. This process includes but is not limited to:
    - A review and approval procedure for new software requests.
    - A maintained list of authorized software.
    - Clear criteria for software approval based on security, functionality, and compliance requirements.

- Enforce strict access controls to prevent unauthorized personnel from installing or executing software. Utilize multi-factor authentication (MFA) and role-based access controls (RBAC) where applicable.

- Implement application whitelisting to ensure that only authorized software can be installed and executed on organizational assets. Regularly update the whitelist to reflect changes in authorized software.

- Deploy anti-malware and endpoint protection solutions to detect and block the installation and execution of unauthorized software. Regularly update these solutions to address new threats.

- Utilize automated monitoring tools to continuously monitor for unauthorized software installation and execution. Implement alerting mechanisms to notify relevant stakeholders of any unauthorized activity.

- Develop and implement incident response plans to address instances of unauthorized software installation or execution. Ensure that incidents are promptly investigated and remediated.

- Conduct regular training and awareness programs for relevant stakeholders to ensure they understand their roles and responsibilities in preventing unauthorized software installation and execution.

- Document the implementation of software authorization, monitoring, and incident response protocols and processes to meet organizational and regulatory requirements. Ensure that all changes and updates are properly documented.

References:

- CIS Controls v8.0: 2.5

- CRI Profile v2.0: PR.PS-05

- CRI Profile v2.0: PR.PS-05.01

- CRI Profile v2.0: PR.PS-05.02

- CRI Profile v2.0: PR.PS-05.03

PR.PS-06: SECURE SOFTWARE DEVELOPMENT PRACTICES

Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle.

Standards:

- Integrate secure software development practices into each phase of the SDLC, from planning and design to development, testing, and maintenance. Secure development practices should include:
    - Threat modeling and risk assessment during the planning and design phase.
    - Secure coding standards and guidelines during the development phase.
    - Code reviews and static code analysis to identify and remediate security vulnerabilities.
- Implement continuous monitoring of secure software development practices to ensure their effectiveness. Utilize automated tools and techniques to monitor code quality, security vulnerabilities, and compliance with secure coding standards.
- Conduct regular security testing throughout the SDLC, including:
    - Static Application Testing (SAST) during development.
    - Dynamic Application Security Testing (DAST) during testing and pre-deployment.
    - Penetration testing during and after deployment to identify and address potential security threats.
- Develop and implement incident response plans to address security vulnerabilities identified during the SDLC. Ensure that vulnerabilities are promptly investigated, remediated, and documented.
- Conduct regular training and awareness programs for software developers and relevant stakeholders to ensure they understand secure software development practices and their roles and responsibilities in maintaining software security.
- Implement configuration management practices to maintain the integrity of software settings and configurations throughout the SDLC. Ensure that changes

to software are documented and approved through Stride's change management process.

- Ensure that third-party software integrated into Stride's ecosystem complies with security development practices. Conduct security assessments and code reviews for third-party software to identify and address potential security risks.

- Document the implementation of secure software development practices and monitoring processes to meet organizational and regulatory requirements. Ensure that all changes and updates are properly documented.

References:

- CIS Controls v8.0: 16.1
- CRI Profile v2.0: PR.PS-06
- CRI Profile v2.0: PR.PS-06.01
- CRI Profile v2.0: PR.PS-06.02
- CRI Profile v2.0: PR.PS-06.03
- CRI Profile v2.0: PR.PS-06.04
- CRI Profile v2.0: PR.PS-06.05
- CRI Profile v2.0: PR.PS-06.06
- CRI Profile v2.0: PR.PS-06.07
- CRI Profile v2.0: PR.PS-06.08
- CRI Profile v2.0: PR.PS-06.09
- CRI Profile v2.0: PR.PS-06.10
- CSF v1.1: PR.IP-2